

Synthetic Aster policy document for payroll hosting. No real organization or customer data. Coverage: production service, 2026-Q3. Rules and qualifications must be read together. The business owner records relationship purpose, data categories and access before assessment. A previous version may describe another service and must not silently replace this version.

The supplier must use multi-factor authentication when administering the payroll hosting service. The access owner maintains separate registers for people and automation. A person can approve a deployment without receiving standing access to the production database. Requests identify the tenant and the operational task. A quarterly review checks active assignments against those requests. Reviewers must distinguish a technical identity used by a scheduled job from a person signing in to the administrative console. Removing an employee must revoke their access even if the next scheduled review has not yet occurred. This requirement excludes non-interactive service identities, which instead need scoped credentials and rotation.

Customer records must be removed within 20 calendar days of contract termination. The customer contact authenticates the removal instruction and names the affected tenant. Operations first disables ordinary use, then tracks removal through the stores listed in the service inventory. A completion receipt records the scope and date. The receiving team checks any requested export before deletion proceeds. A downloadable file alone does not prove a successful handover. Requests concerning invoices follow a separate corporate records schedule and must not be confused with the customer-service data covered here. The stated deadline excludes records under a documented litigation hold; those remain isolated until release is authorized.

The first customer incident notice must be sent within 12 hours of awareness. An on-call coordinator reviews alerts from operators, customers and infrastructure dependencies. The record distinguishes an observation from an unconfirmed hypothesis. Initial communication identifies the affected service, known impact and the next update route. Facts can change while containment continues. Corrections are added to the incident timeline rather than deleting an earlier entry. A tabletop exercise uses synthetic records to rehearse escalation. Completing that exercise does not prove that a real incident occurred or that every future incident will be resolved within the same time. The clock starts with a credible indication affecting customer data, not completion of the root-cause investigation.

Encryption at rest covers the primary store, replicas and recovery copies containing customer data. The component register maps storage classes to accountable owners. A managed key service controls access to key material through a separate role. Support staff can request a redacted configuration sample, but the public assurance pack must not contain key

identifiers or recovery secrets. The storage baseline covers data while stored; transport protection is reviewed independently. A screenshot showing an enabled setting is a declaration about that configuration, and an assessor may need a broader sample before relying on it across every component. Temporary diagnostic exports containing customer records are also in scope, even when they are deleted after troubleshooting.

Primary application processing and storage are located in the European Union. The architecture diagram distinguishes routine computation, disaster recovery and operational support. Corporate office addresses are not used as a substitute for component locations. The supplier register identifies each provider's function and actual access category. Privacy reviewers examine the access route and contractual safeguards together. A provider incorporated abroad need not operate the production database there. Conversely, a database hosted in the agreed region does not establish that every support session originates from that region.

Specialist support in Canada may access the minimum necessary records under a separately approved task; the primary location statement does not exclude that access.

The independent assurance report covers the established production platform for the current review year. The assurance register records the assessor, covered service, period and known exclusions. A company-wide certificate cannot replace the report's stated boundary. The owner can provide an authorized reviewer copy through the assurance contact.

Commercial details may be redacted while retaining the scope statement.

Management tracks outstanding actions separately from completed controls.

An internal operating procedure is useful supporting material, but its existence does not turn an uncovered component into independently assessed infrastructure. It excludes the recently acquired support portal; an extension review is planned but has not been completed.